

Windows Workstation Compromise Investigation Report

Incident Date: March 2, 2019

Executive Summary

A workstation was actively compromised on March 2, 2019. An attacker gained administrative access to the system and installed multiple tools to harvest user passwords, establish persistent backdoor access, and redirect network traffic to their own servers. The attacker also modified system security settings to prevent detection and deployed a web shell to maintain ongoing control.

Immediate action is required to restore security: all user passwords must be reset immediately, malicious scheduled tasks and firewall rules must be removed, the system must be cleaned of malicious files, and the workstation must be isolated from the network until remediation is complete. Additionally, all user accounts that accessed this system should be considered compromised and their passwords reset across the entire network.

We recommend a full system rebuild and thorough audit of other workstations to determine if the compromise spread to other machines.

Scope & Data Sources

Investigation Scope:

This investigation focused exclusively on a single Windows workstation running Windows Server 2016.

Data Sources & Capabilities:

Windows Event Viewer (Security logs) – Provided event logs including login events (Event ID 4624) and privilege assignment events. Allowed us to determine login history, identify the previous RDP user, and timestamp the privilege escalation event.

Limitation: Only reveals what Windows logged; tampered logs could hide earlier attacker activity.

Command-line tools (net user, ipconfig /displaydns) – Enabled extraction of user account metadata (last login time, password expiration, group memberships) and DNS cache inspection.

Limitation: Only shows current state; historical DNS queries older than cache retention are lost.

Task Scheduler – Revealed scheduled tasks and their associated scripts. Allowed identification of the malicious daily cleanup task (Clean File System) and the password dumping task.

Limitation: Only shows active tasks; deleted tasks are unrecoverable without backup.

File system (C:\ drive, inetpub folder) – Exposed the web shell and malicious scripts stored on disk.

Limitation: Does not reveal deleted files or files that were exfiltrated; timestamps may be spoofed.

Windows Defender Firewall rules – Identified non-standard inbound firewall rules opened by the attacker.

Limitation: Does not show deleted or overwritten rules; rules that were reverted do not appear in current state.

System Settings & Registry – Confirmed Windows version and system configuration. Limitation: Full registry analysis was not performed; potential attacker modifications to other registry keys may exist.

Timeline of Events

03/02/2019 – Initial Compromise

- Attacker gains initial access to the workstation. Exact time and initial attack vector not determined from available evidence.
- Attacker successfully authenticates as a user or escalates privileges to Administrator level.

03/02/2019 – Privilege Escalation 4:04:49 PM.

- Windows assigns special privileges to a new logon (Event ID indicates Security Group Management privilege escalation).
- This timestamp represents the attacker establishing administrative access.

03/02/2019 (Everyday 4:55PM) – Persistence Installation

- Attacker creates scheduled task to execute malicious cleanup script daily (Clean File System)

03/02/2019 4:37 PM – Web Shell Deployment

- Attacker uploads malicious web shell file to *C:\inetpub\wwwroot* for ongoing remote access.

03/02/2019 – Ongoing Attacker Activity

- Scheduled tasks execute daily to dump passwords and maintain backdoor access.
- Attacker maintains persistent access via scheduled tasks, firewall rules, and web shell until detected.

Investigation & Analysis

1. User Login History Analysis

- Examined Event Viewer Security logs, filtering for Event ID 4624 (successful logins) with logon type 10 (RDP).
- Finding: Identified the last non-current RDP user prior to investigation.
- Checked net user john output to confirm John's last login time and identify his group memberships.
- Finding: John had logged in previously; Jenny's last login time was also retrieved.

2. System Configuration & Access Analysis

- Used net localgroup Administrators to enumerate all accounts with administrative privileges.
- Finding: Identified two non-default administrator accounts (in addition to the standard Administrator account).
- These accounts may have been exploited or created by the attacker.

3. Startup & Network Behavior Analysis

- Observed terminal opening automatically at system startup, showing connection to a specific IP address.
- Finding: This indicates persistence mechanism or possible attacker reverse shell configured to run at startup.

4. Scheduled Task Analysis

- Inspected Task Scheduler for suspicious scheduled tasks.
- Finding: Discovered a task named Cleaned File System scheduled to run daily at a specific time, executing a cleanup script.
- Finding: Found a second task executing mim.exe, which is the Mimikatz password dumping utility.
- Confirmed via notepad that the first task was indeed executing malicious code.

5. Password Dumping Tool Identification

- Ran PowerShell command: `Get-Content C:\TMP\mim-out.txt`
- Finding: Confirmed that Mimikatz (mim.exe) had successfully dumped system passwords.

6. Command & Control (C2) Infrastructure Analysis

- Ran `ipconfig /displaydns` to inspect local DNS cache.
- Finding: Discovered DNS poisoning entry: `www.google.com` resolving to attacker's IP address.
- This is a common DNS spoofing technique to trick users into accessing attacker-controlled servers.

7. Web Shell & Remote Access Analysis

- Navigated to *C:\inetpub\wwwroot*, the default IIS web root directory.
- Finding: Discovered three files, including a malicious web shell with extension.
- This enables the attacker to execute commands on the system via HTTP requests.

8. Firewall Rule Analysis

- Checked Windows Defender Firewall inbound rules.
- Finding: Identified a suspicious high-priority rule permitting inbound connections on port 1337.

- Rule lacked 'Allow connection if secure' setting, indicating unencrypted backdoor access.

Dead Ends & Ruled Out Hypotheses:

- Legitimate system maintenance: The scheduled tasks and firewall rules were confirmed as malicious through comparison with standard Windows configurations and observation of suspicious command execution patterns.
- Mimikatz evidence shows credential-access activity, but it does not prove exactly which credentials were successfully used afterward.
- Accidental misconfiguration: The specific combination of password dumping, DNS poisoning, web shell deployment, and scheduled backdoor tasks indicates deliberate, coordinated attacker activity, not accidental configuration.

Persistence Mechanisms

The attacker deployed multiple overlapping persistence mechanisms to survive system reboots and password changes:

1. Scheduled Task – Malicious Cleanup Script

- **Detection method:** Task Scheduler GUI inspection
- **Task name:** Clean File System
- **Execution File :** nc.ps1.
- **Execution:** Daily at 4:55PM
- **Purpose:** Suspicious 'cleanup' function that may be covering attacker tracks or disabling security tools.
- **Impact:** Survives reboots; continues running daily unless task is disabled.

2. Scheduled Task – Mimikatz Password Dumping

- **Detection method:** Task Scheduler inspection and PowerShell Get-Content verification
- **Task executes:** mim.exe (Mimikatz)
- **Output file:** C:\TMP\mim-out.txt
- **Purpose:** Extracts plaintext and hash-based credentials from system memory.
- **Impact:** Attacker gains access to all user credentials on the system; survives reboots and standard password resets.

3. Windows Defender Firewall Rule

- **Detection method:** Windows Defender Firewall inbound rules inspection
- **Rule status:** High priority allow rule (listed at top of inbound rules)
- **Port:** 1337
- **Protocol:** TCP
- **Security:** No encryption requirement
- **Purpose:** Opens an unencrypted backdoor port for attacker reverse shell access.
- **Impact:** Attacker can connect to this port and execute commands interactively; survives reboots.

4. DNS Poisoning Entry

- **Detection method:** ipconfig /displaydns DNS cache inspection
- **Fake domain:** www.google.com
- **Resolves to:** Attacker's C2 server IP address(76.32.97.132)
- **Storage location:** Local DNS cache
- **Purpose:** Tricks users or applications into connecting to the attacker's server instead of legitimate Google.
- **Impact:** May redirect traffic for C2 communication, credential theft, or malware delivery. Limited persistence (survives until cache clears, typically at reboot).

5. Web Shell Deployment

- **Detection method:** File system inspection of C:\inetpub\wwwroot
- **File location:** C:\inetpub\wwwroot\b.jsp
- **File extension:** .jsp
- **Purpose:** Allows attackers to execute arbitrary code on the system via HTTP requests to the web server.
- **Impact:** Provides remote code execution channel independent of user login; survives reboots and password changes as long as IIS is running.

Indicators of Compromise (IOCs)

The following table contains actionable indicators that should be searched for across the network to identify other potentially compromised systems:

IOC Type	Value	Where Found	Action
IP	10.34.2.3	C:\TMP\p.exe	Block IP and do further analysis
Scheduled Tasks	1. Clean File System(C:\TMP\nc.ps1) 2. Mimikatz Execution Task(C:\TMP\mim.exe)	Task Scheduler	Retain for analysis
Port	1348	Local listener for nc.ps1.	Kill task PID and block inbound traffic.
Executable File	mim.exe	C:\TMP\	Delete/Retain for analysis
Output File	C:\TMP\mim-out.txt	File System	Delete/Retain for analysis
Firewall Rule	Allow Inbound on port 1337	Windows Defender Firewall	Delete Rule
DNS Entry	www.google.com (C2 IP)	Hosts file	Flush DNS Cache
Web Shell	.jsp	JSP shell artifact under IIS web root.	Investigate
C2 IP	76.32.97.132	DNS Poisoning entry	Block at firewall and investigate logs
Admin Accounts	Guest, Jenny	Local Administrators group	Disable if unused.
Poisoned DNS	google.com	Hosts file	Clean up hosts file

Containment & Recommendations

1. Isolate the workstation from the network immediately. Disconnect the Ethernet cable or disable the wireless adapter to prevent the attacker from maintaining active access.
2. Reset passwords for all user accounts that have ever accessed this workstation, across the entire network (not just on this machine). The attacker has extracted password hashes and likely plaintext passwords via Mimikatz.
3. Reset the local Administrator password on the workstation.
4. Disable or delete the scheduled tasks identified in the Persistence Mechanisms section.
5. Remove the malicious firewall rule allowing inbound access on port 1337.
6. Delete all files in *C:\inetpub\wwwroot* (or at minimum, the malicious web shell file).
7. Perform a full antivirus and malware scan of the system.

Short-Term Actions

1. Audit all other workstations on the network for the presence of IOCs listed in the Indicators of Compromise table.
2. Review firewall logs and network traffic for connections to the attacker's C2 server IP.
3. Check for lateral movement: review login logs on other systems to identify if accounts from this workstation accessed other machines.

Long-Term Changes

1. Implement endpoint detection and response (EDR) software on all workstations to detect suspicious process execution, scheduled task creation, and firewall rule modifications in real-time.
2. Deploy application whitelisting or process blocking rules to prevent tools like Mimikatz from executing.
3. Enable Windows Event Log forwarding to a centralized SIEM to retain and monitor security events beyond local log retention limits.
4. Enforce multi-factor authentication (MFA) on all user accounts to reduce the impact of compromised passwords.
5. Restrict administrative privileges: remove unnecessary users from the local Administrators group and audit unnecessary admin accounts.

Detection Logic – What Should Have Alerted:

Three detection opportunities were missed:

1. **Mimikatz Execution Detection:** Monitor for any process named *mim.exe* or *mimikatz.exe*. This tool is almost exclusively used by attackers and should trigger an immediate alert.

Detection logic: Process creation event (Event ID 4688) where image name contains 'mim' or 'mimikatz' → ALERT

2. **Firewall Rule Modification Detection:** Monitor for creation or modification of Windows Firewall rules via PowerShell. Normal users do not create firewall rules.

Detection logic: Process execution of 'netsh.exe' with arguments containing 'advfirewall' and 'add' → ALERT; PowerShell script containing 'New-NetFirewallRule' → ALERT

3. **Scheduled Task Creation Detection:** Monitor for creation of new scheduled tasks outside of standard administrative processes.

Detection logic: Event ID 4698 (Scheduled Task Created) or 4702 (Scheduled Task Updated) with unusual task names or commands → ALERT

RECOMMENDATION: Full system rebuild. Do not attempt to clean this system.

1. **Multiple persistence mechanisms:** The attacker deployed at least five independent persistence methods (scheduled tasks, firewall rules, web shell, DNS poisoning, plus unknown startup mechanism). Removing one or two does not guarantee all are eliminated.

2. **Unknown initial access vector:** We do not know how the attacker initially compromised the system. Without understanding the entry point, there is no guarantee that removing visible artifacts will prevent re-compromise.
3. **Registry and boot-level modifications:** Detailed registry inspection was not performed. The attacker may have installed rootkits, boot sector modifications, or registry-based persistence that would be difficult to remove safely.
4. **Supply chain risk:** The web shell and scripts may have been signed or packed to evade detection. Cleaning leaves the risk that dormant malware is still present.
5. **Cost-benefit analysis:** The cost of a full rebuild (approximately 2-4 hours including OS installation, patching, application installation, and configuration) is negligible compared to the risk of incomplete remediation and re-compromise.

Rebuild procedure: Fresh Windows installation, apply all OS patches, reinstall only necessary business applications, restore user data from a backup date prior to March 2, 2019, and restore user passwords from a secure identity management system. Do not restore any configuration, scripts, or executable files from the compromised system.